

Information Security Terms Glossary

Week 1 GRC Portfolio Project

Prepared by

Durva Amin

Version

1.0

Date

06 August 2026

Contents

Purpose	2
Scope.....	2
Glossary.....	2
Version History	4

Purpose

This document provides definitions of common information security and cybersecurity terms. It is intended to help beginners understand the fundamental concepts used in cybersecurity and Governance, Risk, and Compliance (GRC). The glossary serves as a quick reference guide for learning and understanding essential security terminology.

Scope

This glossary covers fundamental cybersecurity concepts studied during Week 1, including information security principles, authentication and authorization, common cyber threats, malware, social engineering techniques, and data protection concepts. It is intended for educational purposes and as a foundational reference for future GRC learning.

Glossary

No	Terms	Definition	Real Life Example
1	Cybersecurity	Cybersecurity is the practice of protecting computers, networks, and data from cyber attacks.	A company installs antivirus software to protect its computers.
2	Information Security	Information Security is the practice of protecting information in any form (digital, paper, or verbal) from unauthorised access, modification, or disclosure.	Employee salary records are encrypted to prevent unauthorised access.
3	CIA Triad	CIA Triad is the foundation of Information Security and consists of Confidentiality, Integrity, and Availability.	A hospital protects patient records while ensuring doctors can access them when needed.
4	Confidentiality	Information should be accessed only by authorised people.	Only HR staff can view employee salaries.
5	Integrity	Information should remain accurate, complete, and unchanged unless modified by an authorised person.	A bank ensures transaction records cannot be altered.
6	Availability	Information and systems should be available whenever authorised users need them.	A company keeps backup servers running during outages.

7	Authentication	Authentication is the process of verifying a user's identity before granting access.	Logging into Gmail with a password and OTP.
8	Authorisation	Authorisation answers the question "What are you allowed to do?"	An intern cannot access payroll files.
9	Accounting (AAA)	Accounting answers the question: "What did the user do?"	System logs record who accessed company data and when.
10	Threat	A threat is a possible danger that can exploit a weakness and cause harm.	A hacker attempts to steal customer information.
11	Vulnerability	A vulnerability is a weakness that can be used to cause harm.	An outdated operating system has an unpatched security flaw.
12	Risk	Risk is the chance of damage or loss when a threat exploits a vulnerability.	Weak passwords increase the chance of account compromise.
13	Exploit	An exploit is how a hacker uses a weakness to attack a system.	An attacker uses a software bug to gain unauthorised access.
14	Attack Surface	Attack Surface is all the possible ways an attacker can attack a system.	An exposed web server provides another entry point for attackers.
15	Virus	A virus is a harmful program that needs a host file or program to spread.	An infected USB drive spreads malware to another computer.
16	Worm	A worm is harmful software that spreads by itself over a network.	A worm spreads automatically across computers on a network.
17	Trojan	A Trojan is a fake software that looks genuine but contains malicious code.	A fake game secretly installs malware on a computer.
18	Ransomware	Ransomware locks or encrypts your files and asks for money to unlock them.	Company files are encrypted until a ransom is paid.
19	Spyware	Spyware secretly spies on users and steals their information.	Spyware secretly records a user's online activity.
20	Adware	Adware is software that shows unwanted ads on your computer or mobile device.	A free application displays unwanted advertisements.
21	Rootkit	A Rootkit is malware that hides itself to avoid detection.	A rootkit hides malicious files from antivirus software.

22	Botnet	A botnet is a group of infected devices controlled by a hacker.	Thousands of infected devices launch a DDoS attack together.
23	Phishing	Phishing is a fake message or email sent to steal your personal information.	A fake bank email asks you to enter your password.
24	Spear Phishing	Spear Phishing is a targeted phishing attack aimed at a specific person.	An employee receives a fake email that appears to come from their manager.
25	Whaling	Whaling is a phishing attack that targets CEOs, Directors, or other top executives.	A CEO receives a fake legal notice requesting sensitive information.
26	Vishing	Vishing is phishing through a phone call.	A scammer calls pretending to be from the bank.
27	Smishing	Smishing is phishing through SMS or text messages.	A fake delivery SMS asks you to click a malicious link.
28	Social Engineering	Social Engineering is tricking people instead of hacking computers.	An attacker tricks an employee into revealing a password.
29	Insider Threat	An Insider threat is a trusted person inside the organisation who can cause harm.	An employee copies confidential company data without permission.
30	Confidential Data	Confidential Data is information that must be kept secret.	A company's financial reports are shared only with authorised staff.
31	Personal Data	Personal data is information that identifies an individual.	A customer's name, phone number, and email address are stored securely.
32	Data Classification	Data Classification means grouping data according to how sensitive it is.	A company labels documents as Public, Internal, Confidential, or Restricted.

Version History

Version	Date	Author	Changes
1.0	06 August 2026	Durva Amin	Initial Release